Digital Signatures & PKI

Dr. Mohammed Misbahuddin
Centre for Development of Advanced Computing (C-DAC)
Bangalore

Trust-worthiness in Transactions

The following properties must be assured:

Privacy (Confidentiality): Ensuring that only Authorized persons should read the Data/Message/Document

Authenticity: Ensuring that Data/Message/Document are genuine

Integrity : Ensuring that Data/Message/Document are unaltered by unauthorized person during transmission

Non-Repudiation: Ensuring that one party of a transaction cannot deny having sent a message

Paper Records v/s Electronic Records

Paper Records v/s Electronic Records

	Paper Record	Electronic Record
Privacy (Confidentiality)	Sealed Envelope	Digital Envelope
Authenticity	Hand Signature	Digital Signature
Integrity	Hand Signature	Digital Signature
Non-Repudiation	Hand Signature but it is Challenging	Digital Signature

Hand Signature Vs Digital Signature

- A ***Hand Signature*** on a document is
  - a **unique pattern** dependant on some secret known only to the signer and
  - **Independent of the content** of the message being signed

Attacks on Integrity - 1

Note to kljfklsdajlkj direcljlkfjsdaar afafdasuoiae

This is in reference to the abcd efghigh; kjfasdjfklsadjlksa sdafjsaklfjasdkljfklasdj ioapkafja safiajfskadjfkldsajkl sjaklfjaskl idsuuweporiopwie fsajfklsjaklfjaklj kljlfdsaiou2rjsak iiweop w2uroi32u423 329234 23948198482 23849082390 423892308 42389238094 989908908908908908902 3 42-394239239-09 234 90 klfs9 423kl 9243dsf r9u23ur9 2308974023 jksajfklasjkjk 9jasfjfsad 93284 3248902384 aik iijaa 9irterewr 893423423432 998342 90432i23 234.

Jaja u342290 2999 xfafsi ajjjklajkla324 afasw sawerw rewrwer au23432 423312324 jsdajfaskjk fanci 9324k asfsdajk sajfkaljio sda88ij1412 1jkjkljfklas 411141 fsa80909 2311239 1123132 08934239 243dfafdd 2rerew4 42432423 9890890 111safsaj 423432 4323423423 akfjsdaklj fsdaruw 1as 214 assdfsadjkl.

Fsajdkslajklj faskj (rsekj fskltjakljdkljak 423u9320uiojfskajff dsu9jfsajdajfk) fjklajfkdlajklj asfsdakljk ncasjfksdaju u4223432 namie fasjfsdaiu bad jkdajfkadn infsdafds xisityeu4 4234u32 u8u4i23 fjdskaljfasklj 43223423 8fdajkjk 849423 xcsajku afdasfdsd 439283904423 4423 874892384823 432423423 fsdfjsdkajklj 489023489203890 1243242342 f908908 423423 4080942839089.

(fsdafdsa)
Sf. Fsd fdsajjoilj

Not Approved

Note to kljfklsdajlkj direcljlkfjsdaar afafdasuoiae

This is in reference to the abcd efghigh; kjfasdjfklsadjlksa sdafjsaklfjasdkljfklasdj ioapkafja safiajfskadjfkldsajkl sjaklfjaskl idsuuweporiopwie fsajfklsjaklfjaklj kljlfdsaiou2rjsak iiweop w2uroi32u423 329234 23948198482 23849082390 423892308 42389238094 989908908908908908902 3 42-394239239-09 234 90 klfs9 423kl 9243dsf r9u23ur9 2308974023 jksajfklasjkjk 9jasfjfsad 93284 3248902384 aik iijaa 9irterewr 893423423432 998342 90432i23 234.

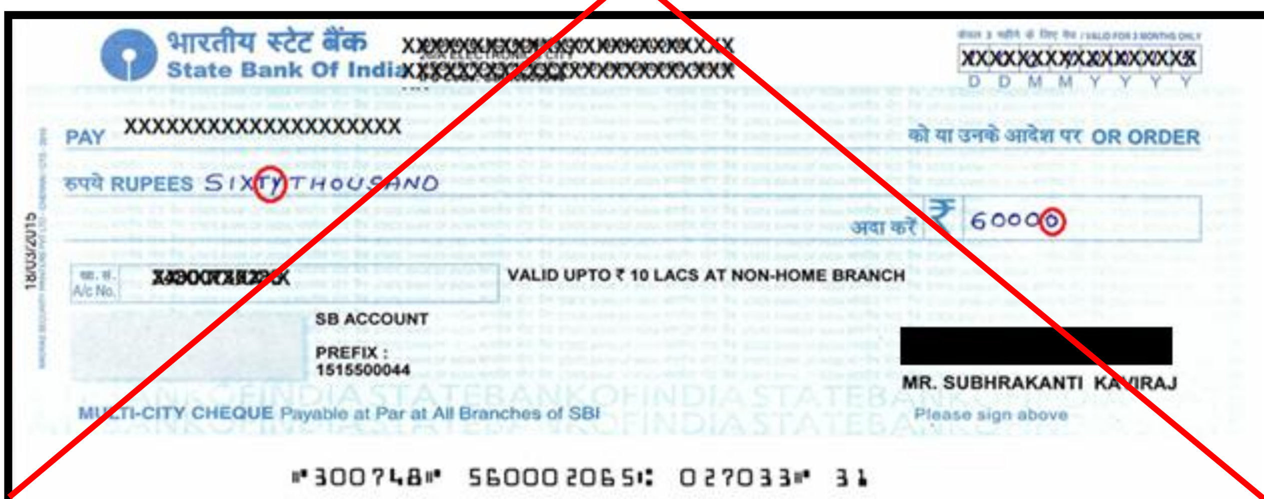
Jaja u342290 2999 xfafsi ajjjklajkla324 afasw sawerw rewrwer au23432 423312324 jsdajfaskjk fanci 9324k asfsdajk sajfkaljio sda88ij1412 1jkjkljfklas 411141 fsa80909 2311239 1123132 08934239 243dfafdd 2rerew4 42432423 9890890 111safsaj 423432 4323423423 akfjsdaklj fsdaruw 1as 214 assdfsadjkl.

Fsajdkslajklj faskj (rsekj fskltjakljdkljak 423u9320uiojfskajff dsu9jfsajdajfk) fjklajfkdlajklj asfsdakljk ncasjfksdaju u4223432 namie fasjfsdaiu bad jkdajfkadn infsdafds xisityeu4 4234u32 u8u4i23 fjdskaljfasklj 43223423 8fdajkjk 849423 xcsajku afdasfdsd 439283904423 4423 874892384823 432423423 fsdfjsdkajklj 489023489203890 1243242342 f908908 423423 4080942839089.

(fsdafdsa)
Sf. Fsd fdsajjoilj

Note Approved

Attacks on Integrity - 2



What is a Digital Signature ?

- A ***Digital signature*** of a message is
  - **a number** dependent on some secret known only to the signer **and**
  - **Dependent on the content** of the message being signed
- Properties of Signatures
  - Verifiable
  - Provides **Authentication**
  - Provides Data **Integrity**
  - Provides **Non-repudiation**

0000000023000000d000000726573705f6964656e74696679000000000000000
6170695f696e666f23000000000000000000000000000000000000000000000
00000000230000000900000072657370 5f696e666f000000000000000000000
6170695f737461747323000000000000000000000000000000000000000000
0000000023000000a000000726573705f7374617473000000000000000000000
6170695f61757468656e746966792378616a505579506d00000000000000000
0000000023000000f000000726573705f61757468656e746966790000000000
6170695f656e6372797074623626c43437979667800000000000000000000000
000000002300000008000000202e01013b3b243a00000000000000000000000
6170695f64656372797074237249 4d586c794f4a000000000000000000000000
00000000238b0408080000000300b0f1a2e3b0d0800000000000000000000000
6170695f627965230000000000000000000000000000000000000000000000000
000000002300000008000000726573705f627965000000000000000000000000
6170695f6964656e74696679234e7a77754a71514300000000000000000000000
0000000023430000d000000726573705f6964656e746966790000000000000000

Creating Digital Signature

- Every individual is given a pair of **keys**
  - ***Public key*** : known to everyone
  - ***Private key*** : known only to the owner

- To ***digitally sign*** an electronic document the signer uses his/her ***Private key***
- To ***verify*** a digital signature the verifier uses the signer's ***Public key***

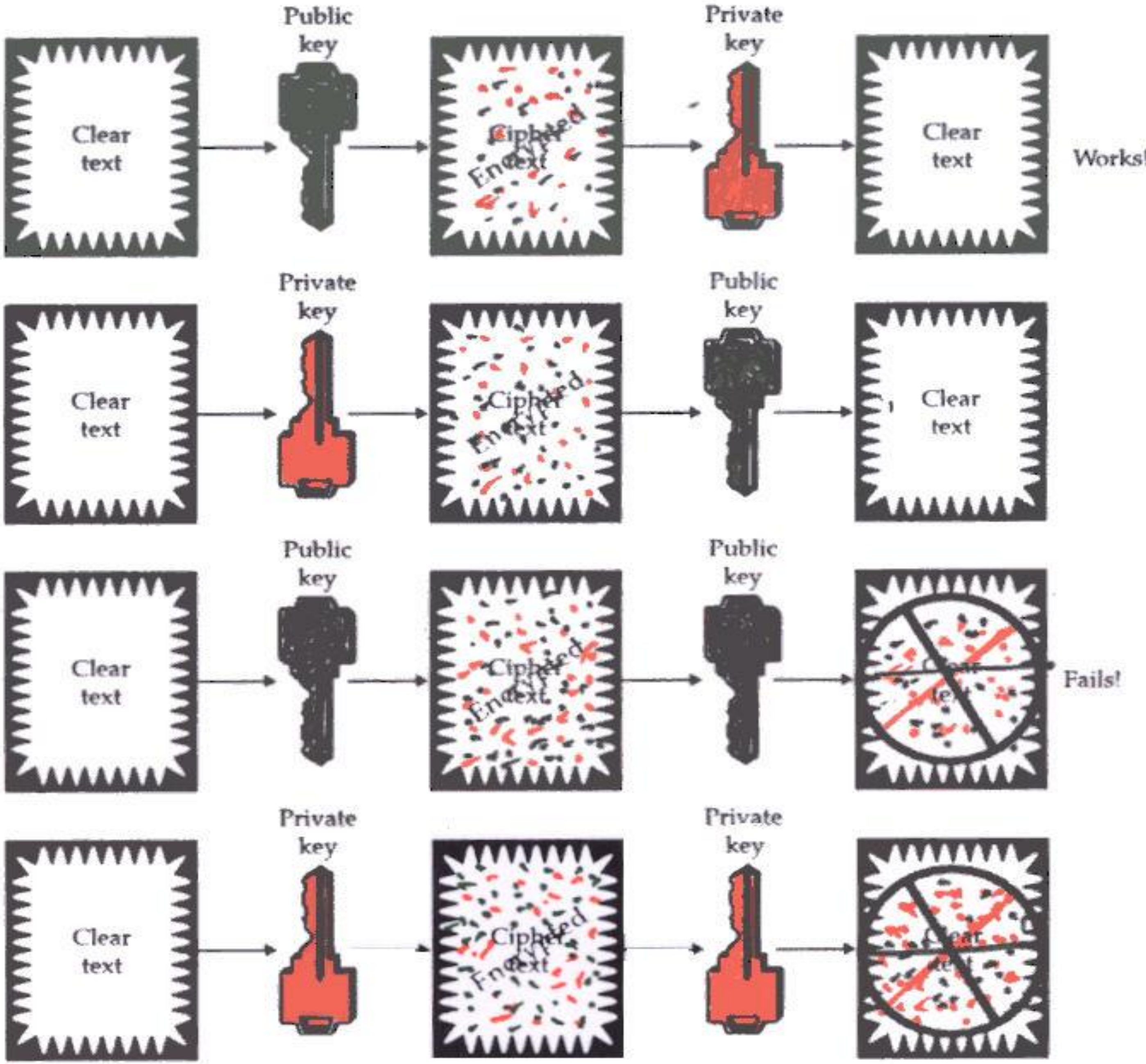
What is a key pair?

Private Key

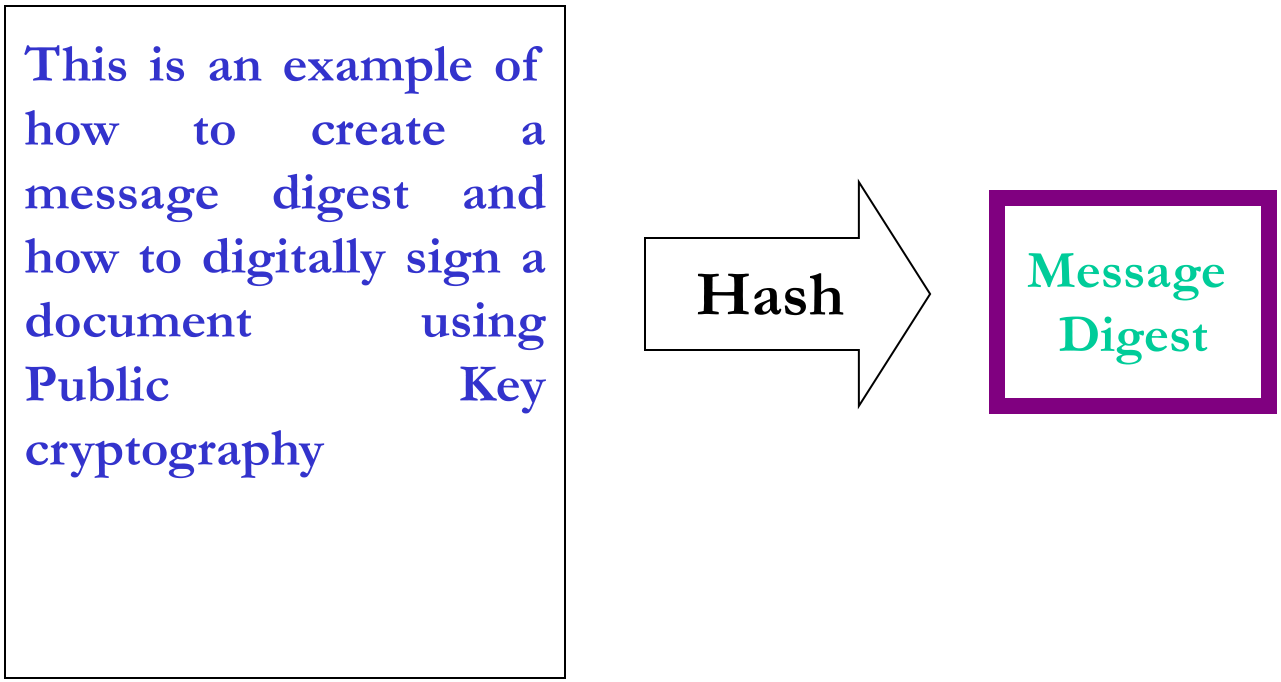
3082 010a 0282 0101 00b1 d311 e079 5543 0708 4ccb 0542 00e2 0d83
463d e493 bab6 06d3 0d59 bd3e c1ce 4367 018a 21a8 efbc ccd0 a2cc
b055 9653 8466 0500 da44 4980 d854 0aa5 2586 94ed 6356 ff70 6ca3
a119 d278 be68 2a44 5e2f cfcc 185e 47bc 3ab1 463d 1ef0 b92c 345f
8c7c 4c08 299d 4055 eb3c 7d83 deb5 f0f7 8a83 0ea1 4cb4 3aa5 b35f
5a22 97ec 199b c105 68fd e6b7 a991 942c e478 4824 1a25 193a eb95
9c39 0a8a cf42 b2f0 1cd5 5ffb 6bed 6856 7b39 2c72 38b0 ee93 a9d3
7b77 3ceb 7103 a938 4a16 6c89 2aca da33 1379 c255 8ced 9cbb f2cb
5b10 f82e 6135 c629 4c2a d02a 63d1 6559 b4f8 cdf9 f400 84b6 5742
859d 32a8 f92a 54fb ff78 41bc bd71 28f4 bb90 bcff 9634 04e3 459e
a146 2840 8102 0301 0001

Public Key

3082 01e4 f267 0142 0f61 dd12 e089 5547 0f08 4ccb 0542 00e2 0d83 463d
e493 bab6 0673 0d59 bf3e c1ce 4367 012a 11a8 efbc ccd0 a2cc b055 9653
8466 0500 da44 4980 d8b4 0aa5 2586 94ed 6356 ff70 6ca3 a119 d278 be68
2a44 5e2f cfcc 185e 47bc 3ab1 463d 1df0 b92c 345f 8c7c 4c08 299d 4055
eb3c 7d83 deb5 f0f7 8a83 0ea1 4cb4 3aa5 b35f 5a22 97ec 199b c105 68fd
e6b7 a991 942c e478 4824 1a25 193a eb95 9c39 0a8a cf42 b250 1cd5 5ffb
6bed 6856 7b39 2c72 38b0 ee93 a9d3 7b77 3ceb 7103 a938 4a16 6c89 2aca
da33 1379 c255 8ced 9cbb f2cb 5b10 f82e 6135 c629 4c2a d02a 63d1 6559
b4f8 cdf9 f400 84b6 5742 859d 32a8 f92a 54fb ff78 41bc bd71 28f4 bb90
bcff 9634 04de 45de af46 2240 8410 02f1 0001


Public key
Private key
Clear text
Encrypted Cipher text
Clear text
Works!
Private key
Public key
Clear text
Encrypted Cipher text
Clear text
Public key
Public key
Clear text
Encrypted Cipher text
Fails!
Private key
Private key
Clear text
Encrypted Cipher text

Digital Signing – Step 1



Digital Signing – Step 1

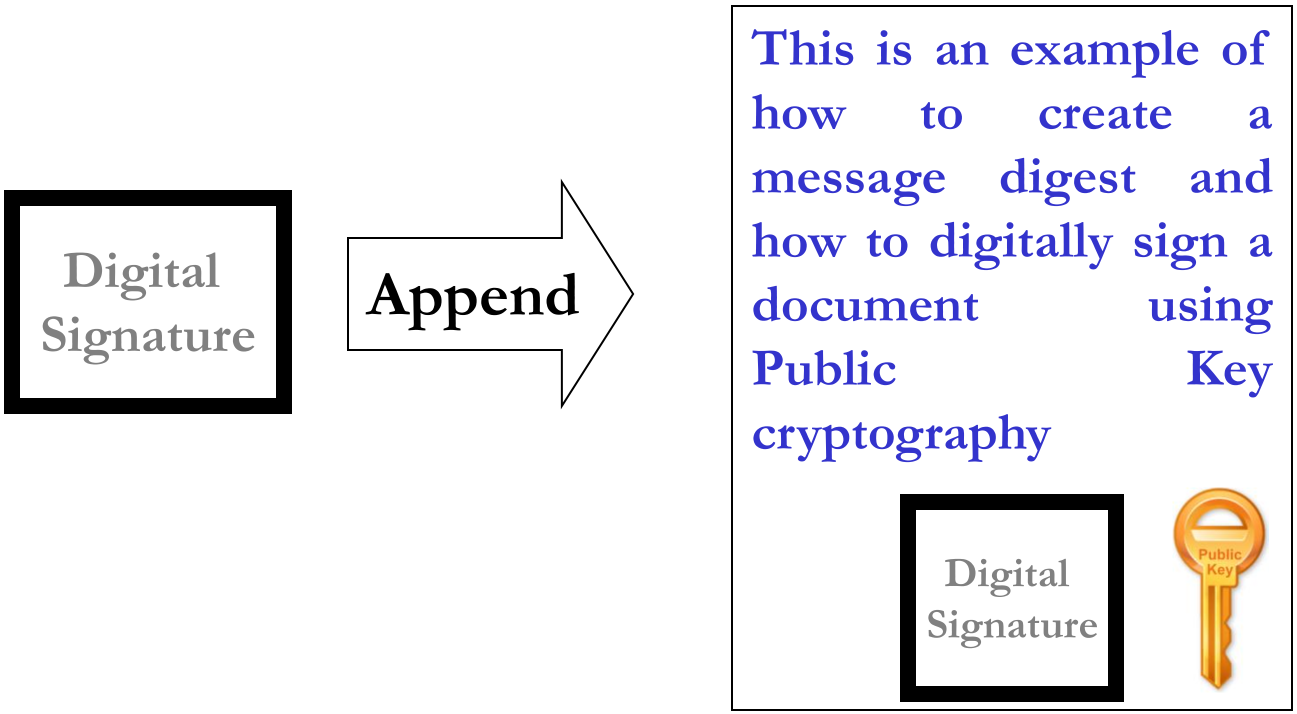
This is an example of how to create a message digest and how to digitally sign a document using Public Key cryptography

Hash

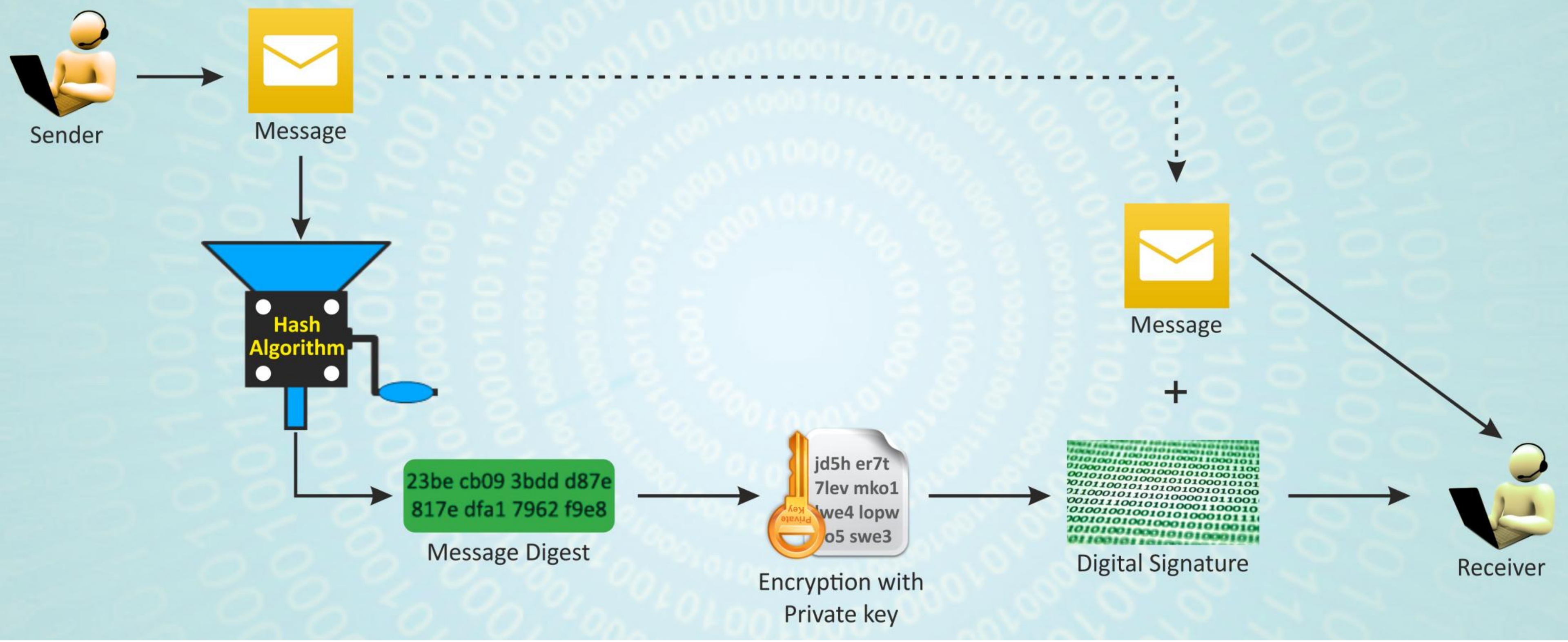
Message Digest

Digital Signing – Step 2

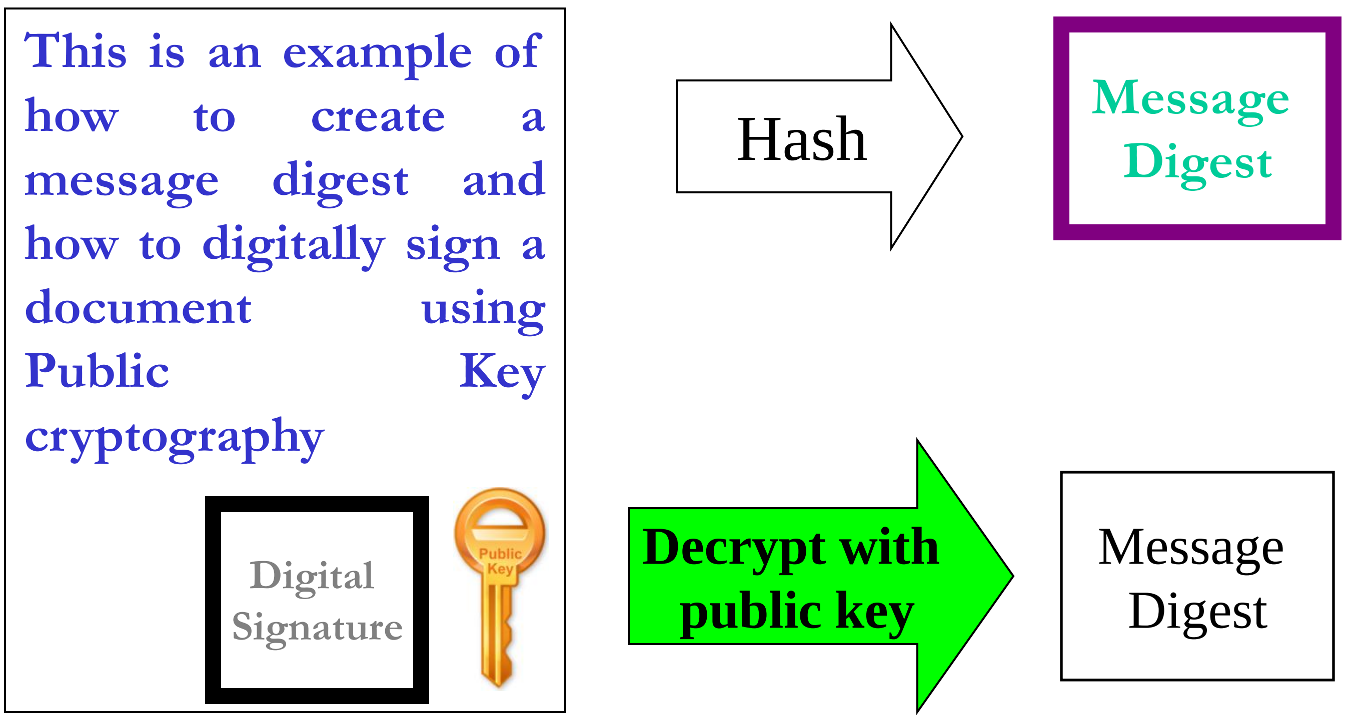
Digital Signing – Step 3



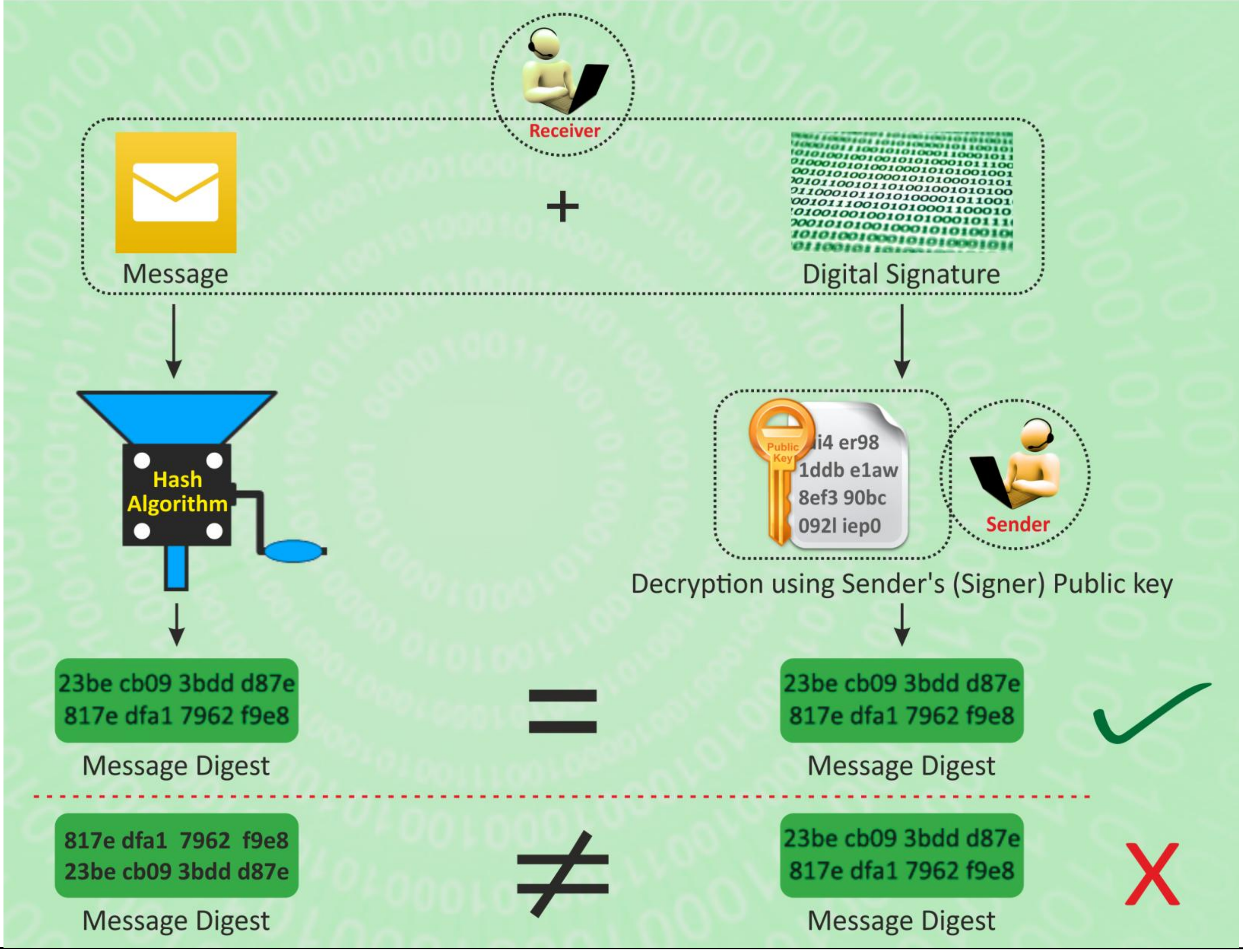
Digital Signing Process



Digital Signature Verification



Digital Signature Verification



Digital Signatures - Examples

I agree

efcc61c1c03db8d8ea8569545c073c814a0ed755

My place of birth is Gwalior.

fe1188eecd44ee23e13c4b6655edc8cd5cdb6f25

I am 62 years old.

0e6d7d56c4520756f59235b6ae981cdb5f9820a0

I am an Engineer.

ea0ae29b3b2c20fc018aaca45c3746a057b893e7

I am a Engineer.

01f1d8abd9c2e6130870842055d97d315dff1ea3

- These are digital signatures of same person on different documents

- **Digital Signatures are numbers**
- **They are content and signer dependent**

What is Digital Signature?

- Message Digest of a message/document when encrypted with the private key of a person is his/her Digital Signature on that e-Document
  - As the public key of the signer is known, anybody can verify the message and the digital signature
  - Digital Signature of a person therefore **varies from document to document** thus ensuring authenticity of each word of that document.

Digital Signatures - Recap

- Establishes
  - Idenity and Authenticity of the Signer
  - Integrity of the document
  - Non-Repudiation (inability to deny being signed) to **a certain extent**
- General Conventions
  - **Signing – Private Key of the Signer**
  - Verification – Public Key of the Signer

Digital Signature Certificate (DSC)

Why do we need DSC?

- To firmly establish the ownership of public key
- To certify and provide a strong mechanism for non-repudiation (to inability to deny)

What is Digital Signature Certificate (DSC)?

DSC is an **electronic document** used to prove ownership of a public key. The certificate includes

- Information about its owner's identity,
- Information about the key,
- The Digital Signature of an entity that has verified the certificate's contents are correct.

Veeru Info:
Name: Veeru
Department: AMD

Certificate Info:
Serial No: 93 15 H0
Exp Date: dd mm yy

Veeru's Public Key

Sign

Digital Certificate

Certifying Authority (CA) ?

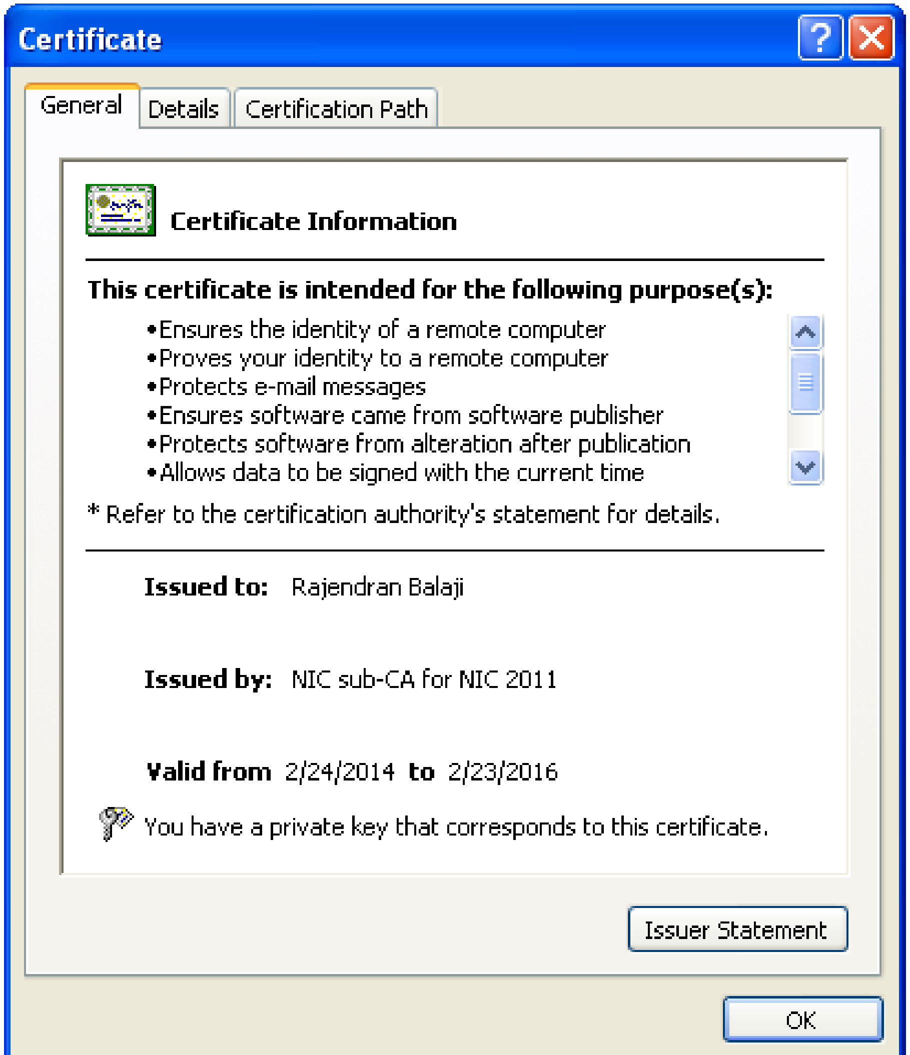
Certifying Authority (CA)

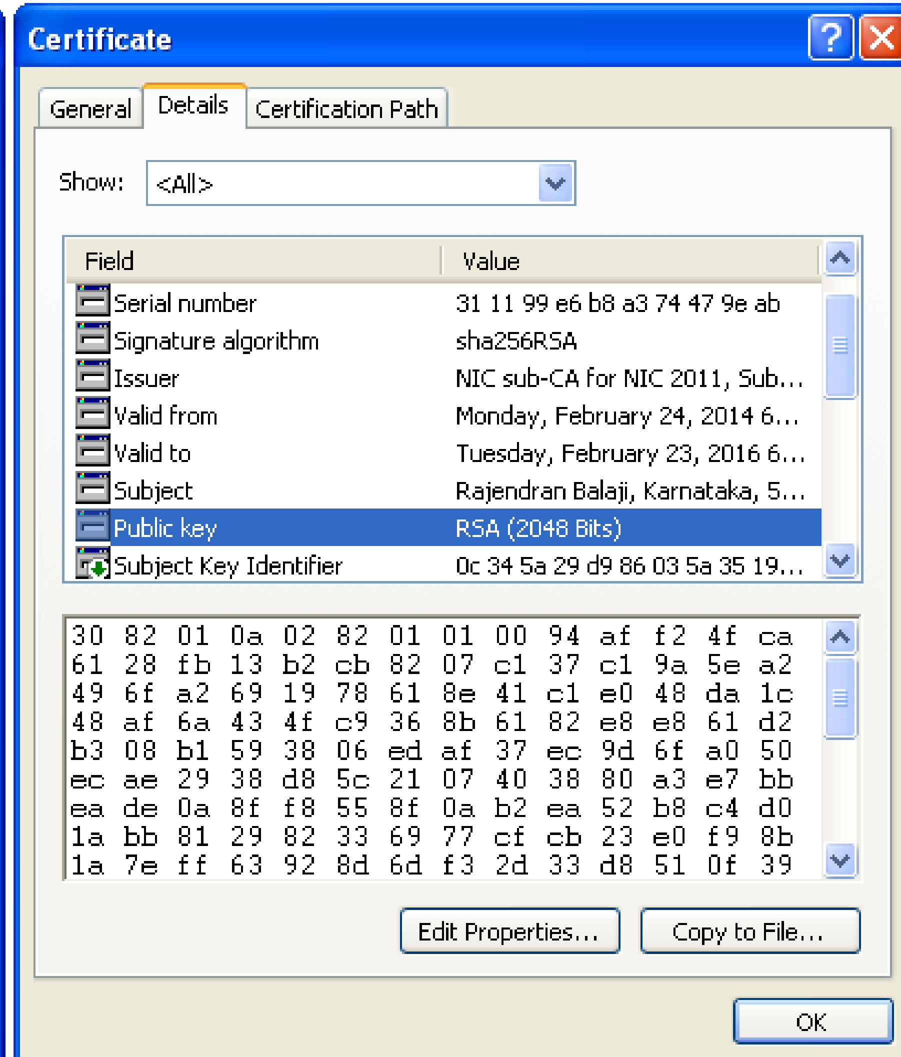
- Certifying authority is an entity which issues Digital Signature Certificate **(DSC)**
- It is a **trusted third party**
- CA's are the important components of Public Key Infrastructure (PKI)

Responsibilities of CA

- Verify the credentials of the person requesting for the certificate (RA's responsibility)
- Issue certificates
- Revoke certificate
- Generate and upload CRL

Sample Certificate

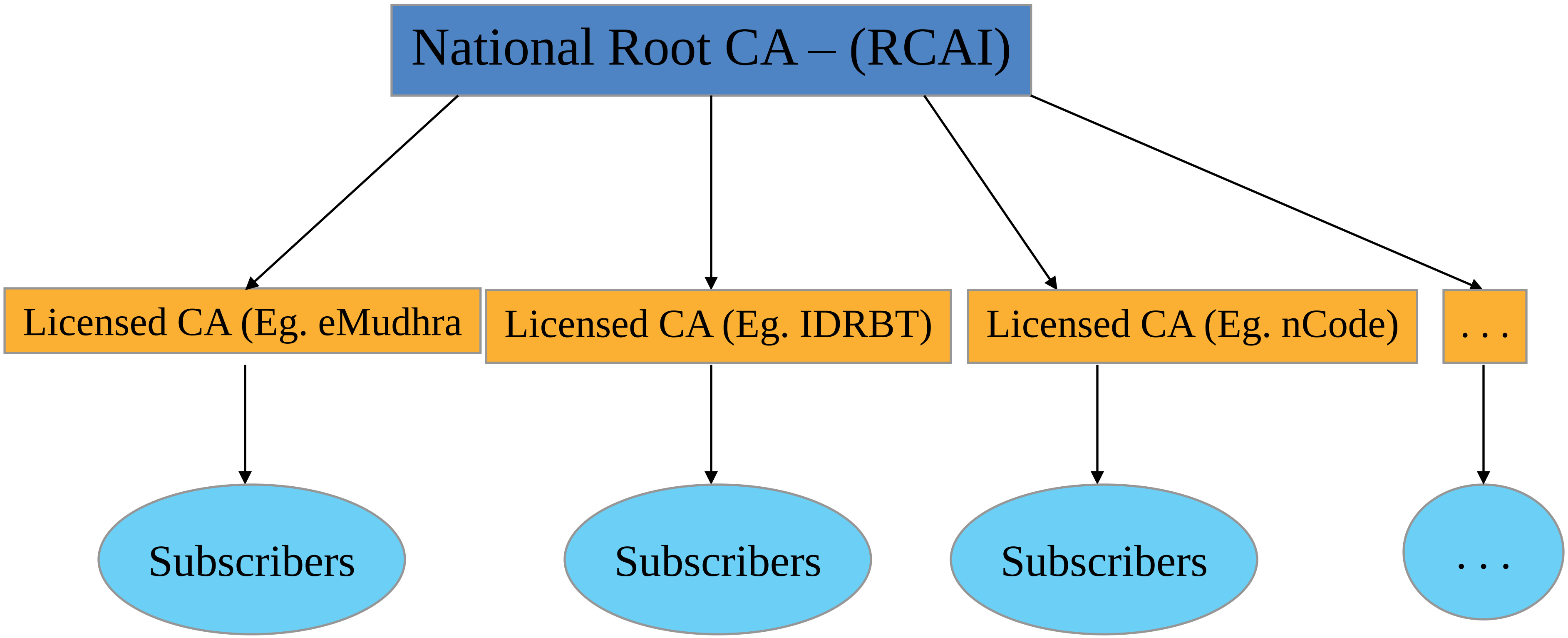




Trust Model

Hierarchical Trust Model

- For a Digital Signature to have legal validity in **India**, it must derive its trust from the Root CA certificate



Licensed CA's in India

- National Root CA (RCAI) – operated by **CCA**
  - Only issues CA certificates for licensed CAs
- 9 CAs licensed under the National Root CA
  - SafeScrypt (www.safescrypt.com)
  - IDRBT CA (www.idbrtca.org.in)
  - National Informatics Centre (https://nicca.nic.in)
  - GNFC - nCode Solutions CA(www.ncodesolutions.com)
  - eMudhra (www.e-mudhra.com)
  - C-DAC (http://esign.cdac.in) – Only e-Sign
  - Capricorn CA
  - NSDL e-Gov CA
  - Air Force CA
- As of Jan, 2018 No. of Digital Certificates issued
  - DSC - 1.97 Crore, since 2002
  - e-Sign – 4.5 Crore, since 2015

Overview of Services offered by licensed CAs

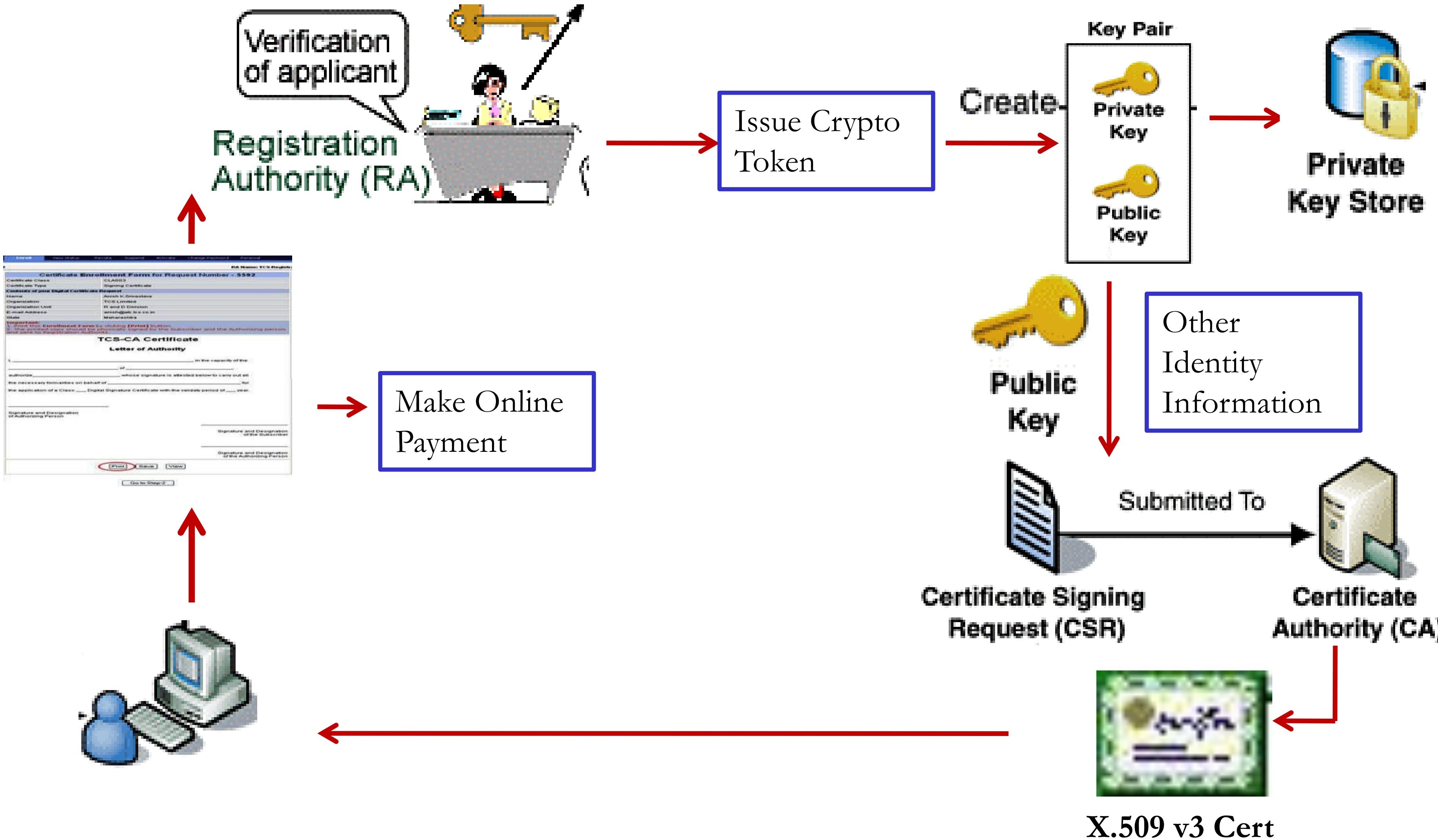
Licensed CAs	CLASS 1-3 DSCs	eSign	SSL & Code Signing certificates	TIMESTAMPING
Safescrypt	✓			✓
IDRBT	✓ ONLY TO BANKS		✓ ONLY TO BANKS	✓ ONLY TO BANKS
NIC				
(n)Code Solutions	✓	✓	✓	✓
e Mudhra	✓	✓	✓	✓
CDAC		✓		
Capricorn	✓	✓		✓
NSDL e-Gov		✓		
Indian Air Force	✓ ONLY TO IAF			✓ ONLY TO IAF

CLOSED CAS

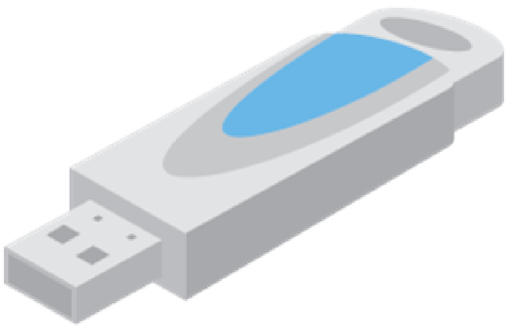
Licensed CAs	CLASS 1-3 DSCs	SSL & CODE SIGINING
MTNL	NA	NA
iCert	NA	NA
TCS	NA	NA

Certificate Issuance Process

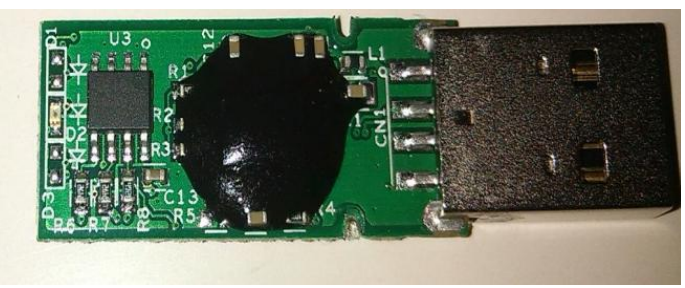
Certificate Issuance Process

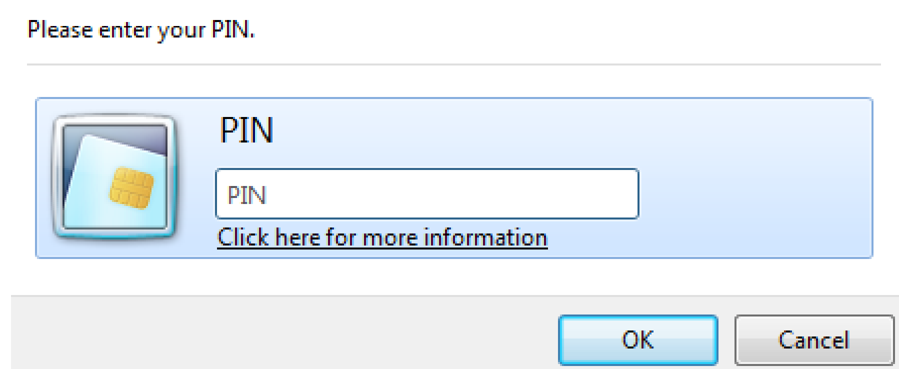


Crypto Tokens



- Contain a Cryptographic co-processor with a USB interface
  - Key is generated inside the token.
  - Key is highly secured as it doesn't leave the token
  - Highly portable and Machine-independent
  - FIPS 140-2 compliant; Tamper-resistant;





Certificate Classes

Classes of Certificates

- 3 Classes of Certificates
  - Class – 1 Certificate
    - Issued to Individuals
    - Assurance Level: **Certificate will confirm User's name and Email address**
    - Suggested Usage: **Signing certificate** primarily be used for signing personal emails and **encryption certificate** is to be used for encrypting digital emails and **SSL certificate** to establish secure communication through SSL

Classes of Certificates

- Class – 2 Certificate
  - Issued for both business personnel and private individuals use
  - Assurance Level: **Conforms the details submitted in the form including photograph and documentary proof**
  - Suggested Usage: **Signing certificate** may also be used for digital signing, code signing, authentication for VPN client, Web form signing, user authentication, Smart Card Logon, Single sign-on and signing involved in e-procurement / e-governance applications, in addition to Class-I usage

Classes of Certificates

- Class – 3 Certificate
  - Issued to Individuals and Organizations
  - Assurance Level: **Highest level of Assurance; Proves existence of name of the organization, and assures applicant's identity authorized to act on behalf of the organization.**
  - Suggested Usage: **Signing certificate** may also be used for digital signing for discharging his/her duties as per official designation and **encryption certificate** to be used for encryption requirement as per his/her official capacity

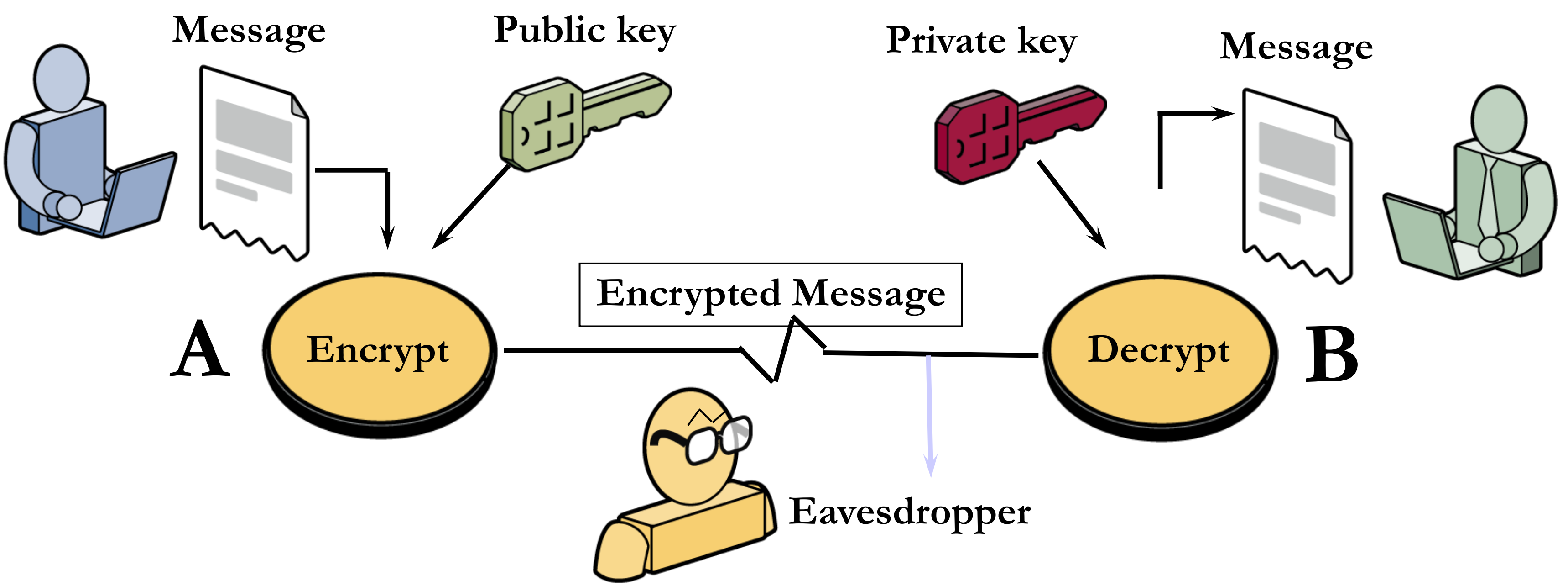
Types of Certificates

Types of Certificates

- Signing Certificate (**DSC**)
  - Issued to a person for signing of electronic documents
- Encryption Certificate
  - Issued to a person for the purpose of Confidentiality;
- TLS Certificate
  - Issued to a Internet domain name (Web Servers, Email Servers etc…)

Achieving Secrecy

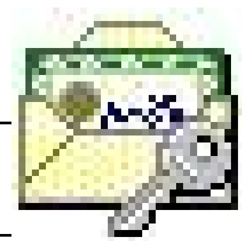
Achieving Secrecy through Asymmetric Key Encryption



General Conventions

- Encryption – Public Key of the Receiver
- Decryption – Private Key of the Receiver

Certificate Extensions

File Formats with Extensions	Description
.CER 	Contains only Public Key
.CRT	Contains only Public Key
.DER	Contains only Public Key
.P12 	Contains Public and Private Key
.PFX	Contains Public and Private Key
.PEM, .KEY, .JKS	Contains Public and Private Key
.CSR	Certificate Signing Request
.CRL	Certificate Revocation List

Certificate Lifecycle Management

- A Digital Signature Certificate cannot be used for ever!
- Typical Life cycle scenario of Digital Certificates
  - Use until renewal
    - Certificates are to be reissued regularly on expiry of validity (typically 2 years)
  - Use until re-keying
    - If keys had to be changed
  - Use until revocation
    - If Certificate was revoked, typically when keys are compromised or CA discovers that certificate was issued improperly based on false documents

CRL – Certification Revocation List

- A list containing the serial number of those certificates that have been revoked
- Why they have been revoked?
  – If keys are compromised and users reports to the CA
  – If CA discovers, false information being used to obtain the certificate
- Who maintains CRLs ?
  – Typically the CA's maintain the CRL

CRL – Certification Revocation List

- How frequently the CRL is updated ?
  - Generally twice a day; based on CA's policies
- Is there any automated system in place for accessing the CRL?
  - Online Certificate Status Protocol - OCSP

Certificate Validation Methods

- **How do you know that the certificate is valid and belongs to that owner ?**

- Validating a certificate is typically carried out by PKI enabled application
- The validation process performs following checks
  - Digital signature of the issuer (CA)
  - Trust (Public Key verification) till root level
  - Time (Validity of the certificate)
  - Revocation (CRL verification)
  - Format

A word of Caution!

- Keep your Digital Security Tokens Safe!
  - Report loss of tokens immediately and seek for revocation from the CA
  - If you have any doubts that private key has been compromised, inform the CA
  - Remember that risks are inherent in any system!
    - Any Security system is only as safe as the weakest link in the security chain!

Objectives of Indian IT Act 2000

- To grant legal recognition to records maintained in electronic form
- To prescribe methods for authenticating electronic records
- To establish a hierarchical trust model with a root CA at the top - CCA to regulate the CAs
- To define computer system and computer network misuse and make it legally actionable

IT Act 2000

- IT Act 2000 made changes in the Law of Evidence, and provides
  - Legal recognition for electronic records and electronic signatures, which paves the way for
    - Legal recognition for transactions carried out by electronic communication
    - Acceptance of electronic filing of documents with the government agencies
    - Changes in the IPC and the Indian Evidence Act 1872 were made accordingly
    - IT Act 2000 has extra-territorial jurisdiction to cover any offense or contravention committed outside India

Regulation of Certifying Authorities

- Under the Indian Law, section 35 of the IT (Amendment) Act, 2000 deals with certification and certifying authorities
- The IT act mandates a hierarchical Trust Model
- The IT Act provides the Controller for Certifying Authorities (CCA) to license and regulate the working of CA.
- The CCA operates RCAI for certifying (signing) the public keys of CA's using it private key

Conclusion

- PKI and Digital Signatures have been transforming the way traditional transactions happen
- PKI Ecosystem has the potential to usher
  - Transparency
  - Accountability
  - Time, Cost & Effort-savings
  - Speed of execution and to be an integral part of
  - **Digital India and bring in Digital Identity**

C-DAC Activities in PKI Domain

- PKI Knowledge Dissemination Program
  - An effort to spread awareness and build competencies in the domain across the country
- PKI Body of Knowledge
  - To develop a BoK with inputs from various sections of users
    - Researchers – Algorithms and new directions in PKI
    - Developers – PKI Administration and implementation issues
    - Policy Makers - Laws
    - End Users and Applications

CCA

References

स्री डैक CDAC

- Cryptography and Network security – Principles and Practice by William Stallings
- Applied Cryptography: Protocols, Algorithms, and Source Code in C by Bruce Schneier
- Handbook of Applied Cryptography, by Alfred Menezes and Paul Van Oorschot
- Ryder, Rodney D, Guide to Cyber Laws, 3rd Edition, Wadhwa & Company, New Delhi
- Digital Certificates: What are they?: http://campustechnology.com/articles/39190_2
- Digital Signature & Encryption: http://www.productivity501.com/digital-signatures-encryption/4710/
- FAQ on Digital Signatures and PKI in India - http://www.cca.gov.in/cca/?q=faq-page
- Controller of Certifying Authorities – www.cca.gov.in
- e-Sign: http://www.cca.gov.in/cca/?q=eSign.html
- More Web Resources
  - Social Media: www.facebook.com/pkiindia @pkiindia

Thank You

misbah@cdac.in